

1. Co to jest PAM i jak działa w kontekście uwierzytelniania?

PAM (Pluggable Authentication Modules) = modułowy system uwierzytelniania w Linuxie

Jak działa:

Użytkownik → Aplikacja (ssh/login/sudo) → PAM → Moduły PAM → Decyzja (allow/deny)

Pliki konfiguracyjne:

bash

```
/etc/pam.d/      # konfiguracje dla poszczególnych usług
/etc/pam.d/common-* # wspólne ustawienia (Debian/Ubuntu)
/etc/security/   # dodatkowe zasady PAM
````
```

#### Typy modułów PAM:

- **auth** - weryfikacja tożsamości (hasło, klucz)
- **account** - sprawdzanie uprawnień (czy konto jest aktywne)
- **password** - zmiana hasła, polityka haseł
- **session** - zarządzanie sesją (logi, montowanie katalogów)

#### Przykład `/etc/pam.d/common-password`:

````

password requisite pam_pwquality.so **retry=3 minlen=12**

password required pam_unix.so sha512 **remember=5**

Najważniejsze moduły:

- **pam_unix.so** - podstawowe uwierzytelnianie
- **pam_pwquality.so** - jakość haseł (długość, złożoność)
- **pam_faillock.so** - blokada po błędnych logowaniach
- **pam_limits.so** - limity zasobów

2. Dlaczego ważna jest historia haseł?

Powody:

a) Zapobiega recyklingowi haseł

bash

Użytkownik nie może użyć ostatnich 5 haseł

password required pam_unix.so remember=5

- Użytkownicy często zmieniają: Hasło1 → Hasło2 → Hasło1
- Historia to blokuje

b) Wymusza rzeczywistą zmianę

- Bez historii: użytkownik może zmienić hasło 5 razy i wrócić do starego
- Z historią: musi wymyślić nowe hasło

c) Bezpieczeństwo po kompromitacji

- Jeśli stare hasło wyciekło, użytkownik nie może go ponownie użyć
- Atakujący nie może użyć starego hasła z bazy danych

d) Zgodność z politykami bezpieczeństwa

- Wiele standardów (PCI DSS, HIPAA) wymaga historii haseł
- Typowo: 5-24 ostatnie hasła

Sprawdź historię:

bash

sudo cat /etc/security/opasswd

3. Jakie są zalety i wady krótkich okresów ważności haseł?

✅ ZALETY (krótkie okresy, np. 30-60 dni):

Bezpieczeństwo:

- Ograniczony czas użycia skradzionego hasła
- Szybsze unieważnienie po kompromitacji
- Trudniejsze ataki brute-force (hasło się zmienia)

Zgodność:

- Wymagane przez standardy (PCI DSS = 90 dni)
- Audyty bezpieczeństwa

Dyscyplina:

- Użytkownicy pamiętają o bezpieczeństwie

✗ WADY (krótkie okresy):

Słabe hasła:

- Użytkownicy wybierają prostsze hasła (łatwiej zapamiętać)
- Stosują przewidywalne wzorce: `Haslo1`, `Haslo2`, `Haslo3`

Zapisywanie haseł:

- Karteczki na monitorze
- Pliki tekstowe na pulpicie
- Niezabezpieczone menedżery haseł

Helpdesk overload:

- Więcej resetów haseł
- Zablokowane konta
- Strata produktywności

Frustracja użytkowników:

- Częste zmiany = niskie morale
- Obejścia zabezpieczeń (np. hasło w skrypcie)

Nowoczesne rekomendacje (NIST 2024):

- **NIE wymuszaj** okresowej zmiany haseł
- Zmieniaj tylko po incydencie
- Zamiast tego: długie hasła (15+ znaków) + MFA

4. Co się stanie z użytkownikami, którzy już mają konta, gdy zmienisz politykę?

Zależy od typu zmiany:

a) Zmiana polityki haseł (`/etc/login.defs`):

Nowi użytkownicy:

bash

PASS_MAX_DAYS 90

PASS_MIN_DAYS 7

PASS_WARN_AGE 14

✓ Automatycznie dostaną nowe zasady

Istniejący użytkownicy: ✗ Zachowują STARE zasady!

Musisz ręcznie zaktualizować:

bash

```
sudo chage -M 90 -m 7 -W 14 username
```

Lub dla wszystkich:

bash

```
for user in $(cut -d: -f1 /etc/passwd | grep -v "^#"); do
```

```
sudo chage -M 90 -m 7 -W 14 $user 2>/dev/null
```

```
done
```

b) Zmiana jakości haseł (PAM):

Plik: **/etc/pam.d/common-password**

bash

```
password requisite pam_pwquality.so minlen=12 ucredit=-1
```

✓ Działa natychmiast dla wszystkich

✗ Ale: istniejące hasła **NIE** są sprawdzane

✓ Nowe zasady obowiązują dopiero przy **zmianie hasła**

Aby wymusić zmianę:

bash

```
sudo chage -d 0 username # wymusza zmianę przy następnym logowaniu
```

c) Zmiana historii haseł:

bash

```
password required pam_unix.so remember=10
```

✓ Działa natychmiast

⚠ Stare hasła (sprzed zmiany) mogą nie być w historii

5. Jak sprawdzić, kiedy użytkownik ostatnio zmienił hasło?

Metoda 1: **chage** (najlepsza)

```
bash
sudo chage -l username
'''
```

Wynik:

```
'''
Last password change           : sty 05, 2026
Password expires               : kwi 05, 2026
Password inactive              : never
Account expires                : never
Minimum number of days between password change : 7
Maximum number of days between password change : 90
Number of days of warning before password expires : 14
'''
```

Metoda 2: **passwd**

```
bash
sudo passwd -S username
'''
```

Wynik:

```
'''
username P 01/05/2026 7 90 14 -1
'''
```

Format: **użytkownik status data_zmiany min max warn inactive**

Metoda 3: Bezpośrednio z **/etc/shadow**

```
bash
sudo cat /etc/shadow | grep username
'''
```

Wynik:

```
'''
username:$6$xyz....:19723:7:90:14:::
'''
```

Pole **19723** = dni od 1 stycznia 1970 (epoch)

Przelicz na datę:

bash

```
echo $(( $(date +%s) / 86400 )) # dzisiejsza data w dniach epoch
```

Lub:

bash

```
sudo awk -F: '/^username/ {print $3}' /etc/shadow | xargs -I {} date -d "1970-01-01 {} days"
```

Metoda 4: Dla wszystkich użytkowników

bash

```
for user in $(cut -d: -f1 /etc/passwd); do
  echo "=== $user ==="
  sudo chage -l $user 2>/dev/null | grep "Last password"
done
```

Metoda 5: Tylko użytkownicy ze starymi hasłami (>90 dni)

bash

```
sudo awk -F: '$3 < $(echo $(date +%s)/86400-90 | bc)' {print $1}' /etc/shadow
```

Podsumowanie:

1. **PAM** = modułowy system uwierzytelniania, konfiguracja w `/etc/pam.d/`
2. **Historia haseł** = zapobiega recyklingowi, wymusza nowe hasła
3. **Krótką ważność** =  bezpieczeństwo,  słabe hasła i frustracja (NIST: nie wymuszaj)
4. **Zmiana polityki** = nowi users automatycznie, starzy users wymagają `chage`
5. **Sprawdź zmianę hasła** = `sudo chage -l username`